



Reconnaissance - Ping Sweeping and Port Scanning Attacks and Defense

Reconnaissance is the first phase in any cyber kill chain. An example is shown in Figure 1.

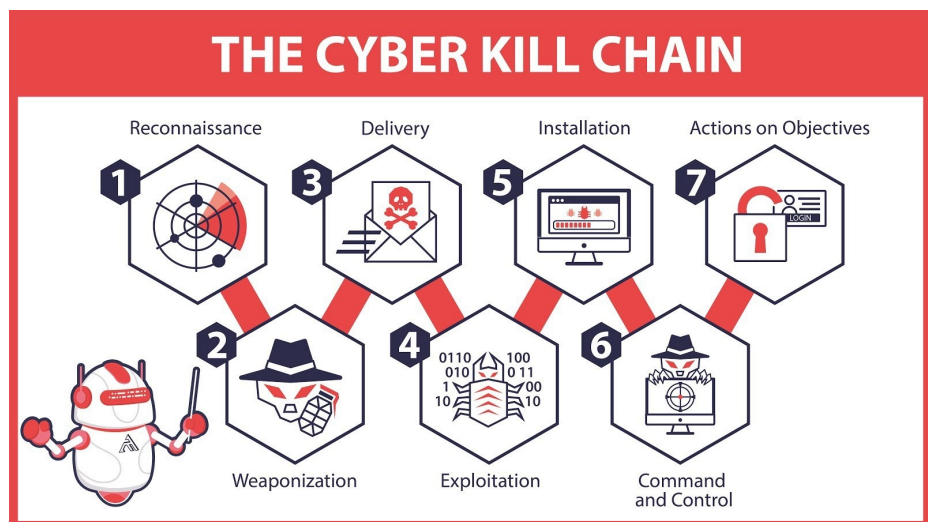


Figure 1

Under the reconnaissance phase, **ping sweeping** and **port scanning** are typically conducted:

- **Ping sweeping** or **host discovery**: to reduce a (possibly large) block of IP addresses into a smaller set of active or interesting targets;
- **Port scanning** or **service discovery**: a time-consuming process and hence typically conducted after ping sweeping to determine the ports or services available at the targets to exploit.

The Nmap (Network Mapper) Scanning Tool

Nmap is an open source tool for network exploration and security auditing commonly used for conducting **ping sweeping** and **port scanning** in practice. It is a powerful tool which can employ different techniques to scan a network for live hosts and services, possibly bypassing firewall security if not configured properly.

Refer to the [Nmap Reference Guide](#) for a complete list of host discovery and port scanning techniques and the [The Official Nmap Project Guide to Network Discovery and Security Scanning](#) for more details.

Figure 2 shows an **nmap cheat sheet** on the various options available which can be confusing for a beginner. To understand nmap operations, it's instructional to categorize the various options based on the layers of the network protocol stack as elaborated below.

Base Syntax

```
# nmap [ScanType] [Options] {targets}
```

Target Specification

IPv4 address: 192.168.1.1
 IPv6 address: AABB:CCDD::FF%eth0
 Host name: www.target.tgt
 IP address range: 192.168.0-255.0-255
 CIDR block: 192.168.0.0/16
 Use file with lists of targets: -iL <filename>

Target Ports

No port range specified scans 1,000 most popular ports

- F Scan 100 most popular ports
- p<port1>-<port2> Port range
- p<port1>,<port2>,... Port List
- pU:53,U:110,T20-445 Mix TCP and UDP
- r Scan linearly (do not randomize ports)
- top-ports <n> Scan n most popular ports
- p-65535 Leaving off initial port makes Nmap scan start at port 1
- pO- Leaving off end port makes Nmap scan up to port 65535
- p- Leaving off start and end port makes Nmap scan ports 1-65535



Aggregate Timing Options

- T0 Paranoid: Very slow, used for IDS evasion
- T1 Sneaky: Quite slow, used for IDS evasion
- T2 Polite: Slows down to consume less bandwidth, runs -T0 times slower than default
- T3 Normal: Default, a dynamic timing model based on target responsiveness
- T4 Aggressive: Assumes a fast and reliable network and may overwhelm targets
- T5 Insane: Very aggressive; will likely overwhelm targets or miss open ports

Probing Options

- Pn Don't probe (assume all hosts are up)
- PB Default probe (TCP 80, 445 & ICMP)
- PS<portlist>
Check whether targets are up by probing TCP ports
- PE Use ICMP Echo Request
- PP Use ICMP Timestamp Request
- PM Use ICMP Netmask Request

Scan Types

- sn Probe only (host discovery, not port scan)
- sS SYN Scan
- sT TCP Connect Scan
- sU UDP Scan
- sV Version Scan
- O OS Detection
- scanflags Set custom list of TCP using URGACKPSHRSTSYNFIN in any order

Output Formats

- oN Standard Nmap output
- oG Greppable format
- oX XML format
- oA <basename>
Generate Nmap, Greppable, and XML output files using basename for files

Misc Options

- n Disable reverse IP address lookups
- 6 Use IPv6 only
- A Use several features, including OS Detection, Version Detection, Script Scanning (default), and traceroute
- reason Display reason Nmap thinks port is open, closed, or filtered





Figure 2

For Layer 2, nmap supports **ARP scan** as shown in Figure 3 which sends out ARP requests and awaiting ARP replies. This is the default when scanning the **same subnet** in an Ethernet LAN where nmap is running. Since ARP operation is essential and cannot be filtered, it is sure to discover live hosts in the subnet.

```
$ sudo nmap network-to-scan
```

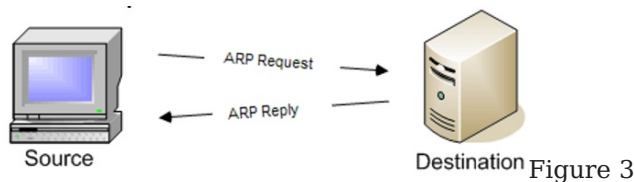


Figure 3

If not scanning the same subnet where nmap is running, e.g. scanning from the Internet, other nmap options operating at higher layers will need to be described next.

For Layer 3, nmap supports **IP Protocol scan** as shown in Figure 4 which sends out IP packets with different values in the IP header protocol field as specified in the *protocol-list*, e.g. -PO1-2,4. Note that there is no space between -PO and *protocol-list*. If not specified, the default is to send protocol 1 (ICMP), 2 (IGMP) and 4 (IP-in-IP).

```
$ sudo nmap -PO<protocol-list> network-to-scan
```

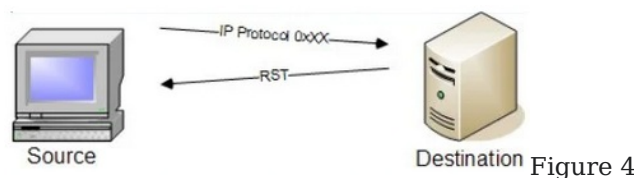


Figure 4

In addition, nmap supports the traditional **ICMP ping scan** as shown in Figure 5. Unfortunately, ICMP ping is typically blocked by firewall and hence not so useful in practice.

```
$ sudo nmap -PE network-to-scan
```

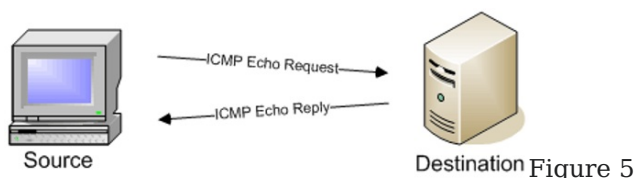
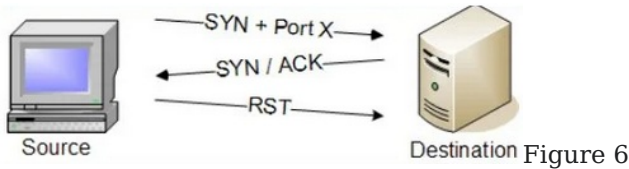


Figure 5

For Layer 4, nmap supports **TCP SYN scan** as shown in Figure 6 which initiates a SYN connection and hence likely will be blocked if scanning from the Internet. The syntax for *port-list* is similar as *protocol-list*. If not specified, the

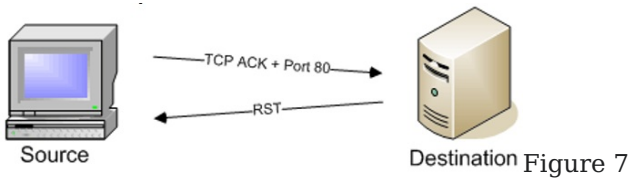
default is to send to port 80.

```
$ sudo nmap -PS<port-list> network-to-scan
```



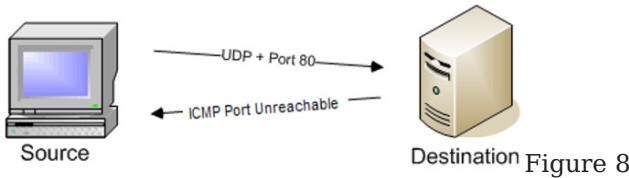
As an alternative, nmap supports **TCP ACK scan** as shown in Figure 7 which sends out TCP with ACK flag set to emulate the characteristic of return network traffic to bypass packet-filtering firewall. Similarly, the default is to send to port 80 if *port-list* is not specified.

```
$ sudo nmap -PA<port-list> network-to-scan
```



For Layer 4, nmap also supports **UDP scan** as shown in Figure 8 which sends out UDP datagram to the ports as specified in the *port-list*. If not specified, the default is to send to port 40125 which is a highly unlikely port to be used so as to solicit an ICMP port unreachable error message if the target host is alive.

```
$ sudo nmap -PU<port-list> network-to-scan
```



Next, based on the responses from the targets being scanned, or no response due to possibly being blocked by the firewalls, nmap classifies the target ports to be **open**, **closed**, **filtered**, **unfiltered**, **open/filtered**, **closed/filtered**. Please read [Nmap Port Scanning Basics](#) for an understanding of these classifications.

Note the UDP scan in Figure 8 where nmap is soliciting for **ICMP port unreachable** error message to determine whether a host is alive. In fact, there are other **ICMP destination unreachable** error messages as shown in Figure 9.

Type	Code	Description
3 Destination Unreachable	0	Destination network unreachable
	1	Destination host unreachable
	2	Destination protocol unreachable
	3	Destination port unreachable
	4	Fragmentation required, and DF flag set
	5	Source route failed
	6	Destination network unknown
	7	Destination host unknown
	8	Source host isolated
	9	Network administratively prohibited
	10	Host administratively prohibited
	11	Network unreachable for ToS
	12	Host unreachable for ToS
	13	Communication administratively prohibited
	14	Host Precedence Violation
	15	Precedence cutoff in effect

Figure 9

For example, a firewall configured to block nmap scan may send the **ICMP communication administratively prohibited** error message as shown in Figure 10 which could leak information to the attacker.

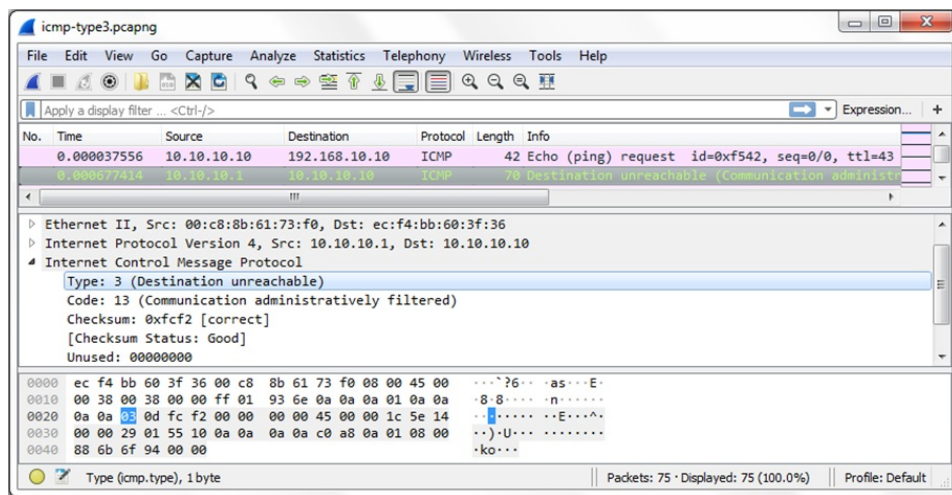


Figure 10

Defending against Ping Sweeping and Port Scanning Attacks

To prevent ping sweeping and port scanning attacks, a naive approach may be to simply apply an ACL on the edge router to filter the scans, an example as shown in Figure 11.

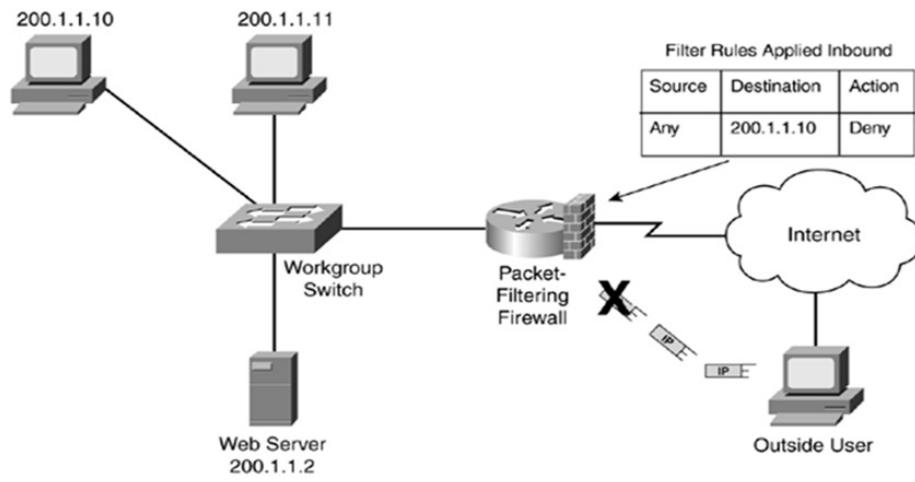


Figure 11

Unfortunately, naively applying ACL to prevent ping sweeping and port scanning attack will also prevent users in the enterprise network from accessing the Internet since the return network traffic will be filtered as shown in Figure 12.

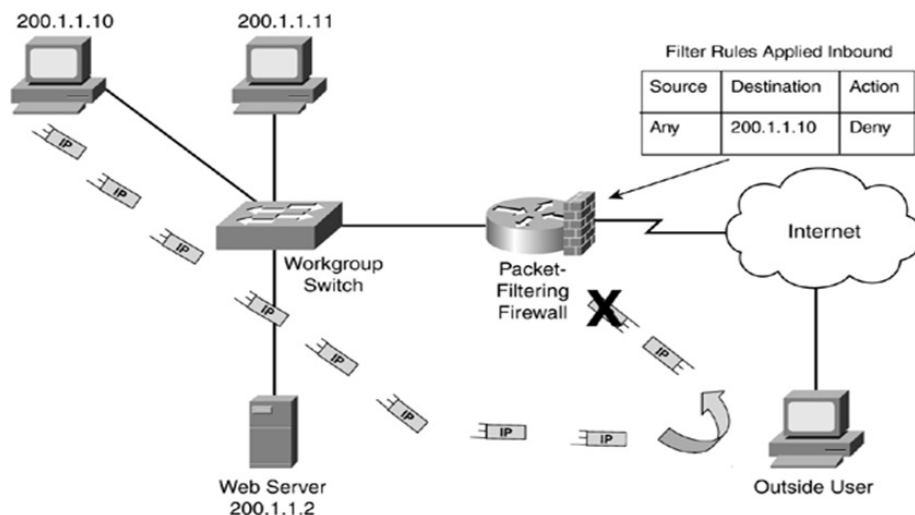


Figure 12

To overcome the limitation, **ACL** can be configured with the **established** parameter to allow return network traffic but filter away other network traffic initiated from the Internet as shown in Figure 13.

```
router(config-ext-nacl)# permit tcp any 200.1.1.0 0.0.0.255 established
```

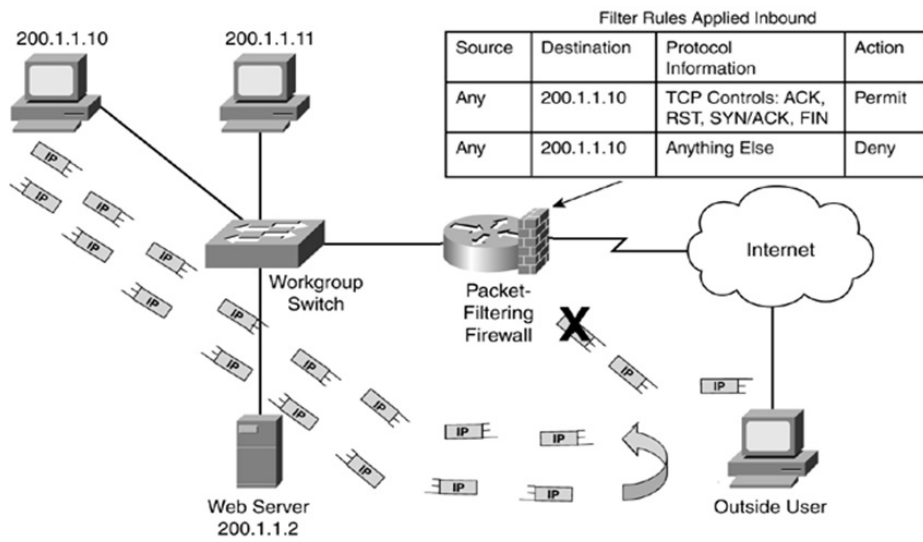



Figure 13

From Figure 13, we can see that **ACL with established** works by permitting packets with **TCP flags** set on either ACK, RST, SYN/ACK or FIN which are characteristics of return traffic, and denying other packets.

In fact, **ACL** can be written to inspect on specific **TCP flags**. For example:

```
router(config)# ip access-list extended acl-id
router(config-ext-nacl)# permit tcp any any match-all +ack
router(config-ext-nacl)# permit tcp any any match-all +rst
router(config-ext-nacl)# permit tcp any any match-all +syn +ack
router(config-ext-nacl)# permit tcp any any match-all +fin
```

In addition, to prevent leaking information to nmap scan as shown in Figure 10, a recommended defense is to configure the interface not to reply ICMP unreachable error messages when dropping scanning packets:

```
router(config)# interface int-id
router(config-if)# no ip unreachable
```

Unfortunately, there are **limitations** of **packet-filtering firewall** in defending against ping sweeping and port scanning attacks. For better defense, **stateful inspection firewalls** are recommended which by default will only permit return network traffic and deny all other traffic initiated from the Internet, thus including all ping sweeping and port scanning traffic, except when ACL is specifically applied to permit Internet users to access, e.g. for servers hosted at the DMZ.